

HoneyBOT實驗室

指示：

解壓縮實驗室（密碼：cyberdefenders.org）

PCAP 分析練習重點介紹了攻擊者與蜜罐的互動以及自動利用的工作原理。（請注意，受害者的 IP 位址已被更改以隱藏真實位置。）

作為社會分析師，分析工件並回答問題。

Tools:

Brim

NetworkMiner

Wireshark

Libemu (sctest)

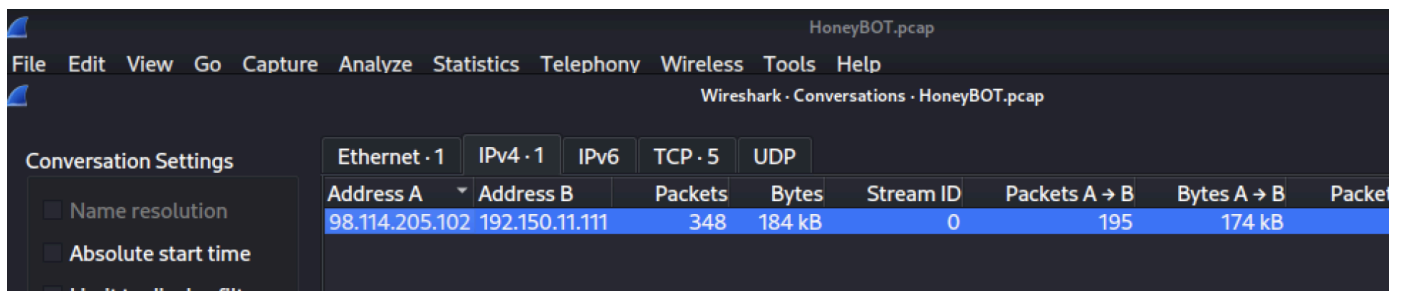
scdbg

IP LookUp

Q1

Solved : 2322

What is the attacker's IP address?



The screenshot shows the Wireshark interface with the 'Conversations' pane selected. The table lists a conversation between 98.114.205.102 and 192.150.11.111. The attacker's IP address, 98.114.205.102, is highlighted in the first column.

Address A	Address B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B
98.114.205.102	192.150.11.111	348	184 kB	0	195	174 kB

98.114.205.102

Q2

What is the target's IP address?

同上

192.150.11.111

Q3

Provide the country code for the attacker's IP address (a.k.a geo-location).

Geolocation info



Search IP

Geolocation

Network

Misc

Currency

Security

US

IP:	98.114.205.102
Hostname:	pool-98-114-205-102.phlapa.fios.verizon.net
City:	Philadelphia
District / County:	Philadelphia County
State Code:	US-PA
State / Province:	Pennsylvania
Country Name:	United States
Country Name Official:	United States of America
Country Capital:	Washington, D.C.
Country Code (ISO-2):	US
Country Code (ISO-3):	USA
Country Flag:	https://ipgeolocation.io/static/flags/us_64.png

Q4

How many TCP sessions are present in the captured traffic?

HoneyBOT.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Wireshark · Conversations · HoneyBOT.pcap

Conversation Settings		Ethernet · 1	IPv4 · 1	IPv6	TCP · 5	UDP				
		Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percentage
☐ Name resolution		98.114.205.102	1821	192.150.11.111	445	7	412 byte	0	7	
☐ Absolute start time		98.114.205.102	1828	192.150.11.111	445	31	7 kB	1	31	
☒ Limit to display filter		98.114.205.102	1924	192.150.11.111	1957	12	817 byte	2	12	
		98.114.205.102	2152	192.150.11.111	1080	271	173 kB	4	271	
		192.150.11.111	36296	98.114.205.102	8884	27	2 kB	3	27	

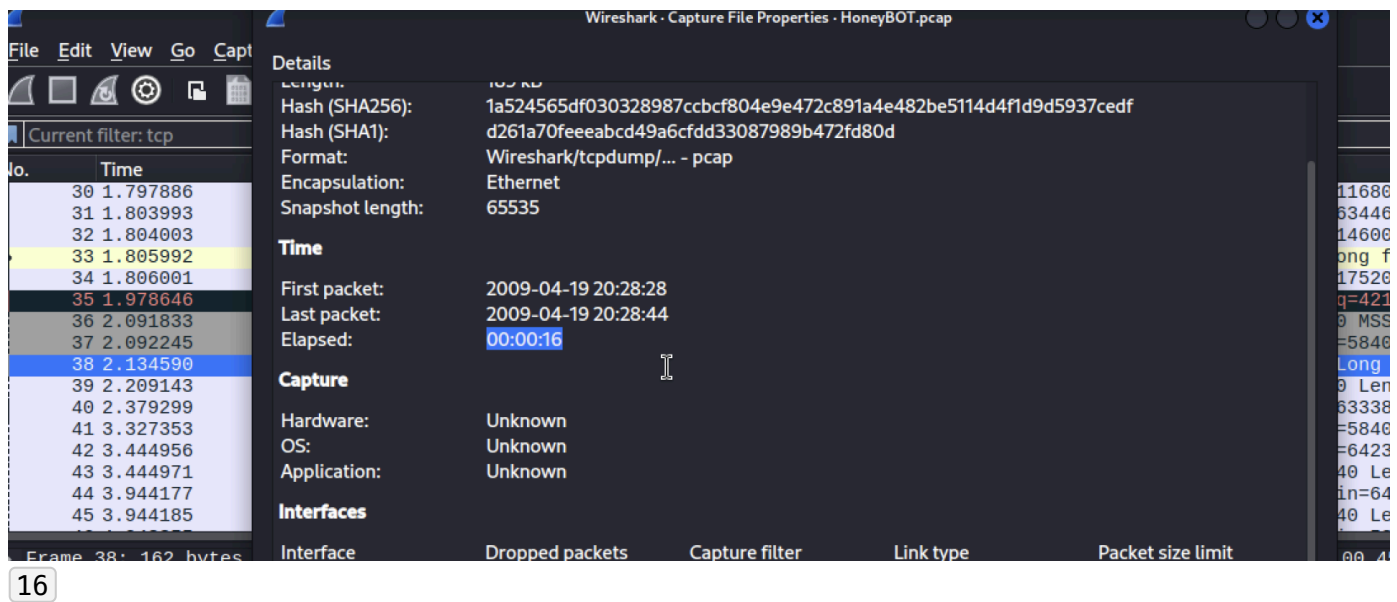
Copy

Follow Stream...

5

Q5

How long did it take to perform the attack (in seconds)?



16

Q6

Provide the CVE number of the exploited vulnerability.

SMB有遠程呼叫

Wireshark · Protocol Hierarchy Statistics · HoneyBOT.pcap

Protocol	Percent Packets	Packets	Percent Bytes
Frame	100.0	348	100.0
Ethernet	100.0	348	2.7
Internet Protocol Version 4	100.0	348	3.8
Transmission Control Protocol	100.0	348	4.0
Socks Protocol	44.5	155	86.5
NetBIOS Session Service	4.0	14	2.8
SMB (Server Message Block Protocol)	4.0	14	2.8
SMB Pipe Protocol	1.1	4	0.0
Distributed Computing Environment / Remote Procedure Call (DCE/RPC)	1.1	4	1.9
Active Directory Setup	0.6	2	1.8
Data	5.7	20	0.2

查詢

HoneyBOT.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

smb and ip.src==98.114.205.102

No.	Time	Source	Destination	Protocol	Length	Info
10	0.267724	98.114.205.102	192.150.11.111	SMB	191	Negotiate Protocol Request
14	0.602288	98.114.205.102	192.150.11.111	SMB	222	Session Setup AndX Request, NTLMSSP_NEGOTIATE
17	0.840405	98.114.205.102	192.150.11.111	SMB	276	Session Setup AndX Request, NTLMSSP_AUTH, User: \
20	1.073151	98.114.205.102	192.150.11.111	SMB	152	Tree Connect AndX Request, Path: \\192.150.11.111\ipc\$
23	1.307145	98.114.205.102	192.150.11.111	SMB	158	NT Create AndX Request, FID: 0x4000, Path: \lsarpc
26	1.542389	98.114.205.102	192.150.11.111	DCERPC	214	Bind: call_id: 1, Fragment: Single, 1 context items: DSSETU
33	1.805992	98.114.205.102	192.150.11.111	DSSETUP	454	DsRoleUpgradeDownlevelServer request[Long frame (3208 bytes)

Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
 Frag Length: 3232
 Auth Length: 0
 Call ID: 1
 Alloc hint: 3208
 Context ID: 0
 Opnum: 9
 [Response in frame: 38]
 Complete stub data (3208 bytes)
 Active Directory Setup, DsRoleUpgradeDownlevelServer
 Operation: DsRoleUpgradeDownlevelServer (9)
 [Response in frame: 38]
 Long frame
 [Expert Info (Warning/Protocol): Long frame]
 [Long frame]
 [Severity level: Warning]
 [Group: Protocol]

0000 00 30 48 62 4e 4a 00 08 e2
 0010 01 b8 3c 3f 40 00 71 06 d0
 0020 0b 6f 07 24 01 bd 08 d0 06
 0030 f7 d6 c6 e6 00 00 31 31 31
 0040 31 31 31 31 31 31 31 31 31
 0050 31 31 31 31 31 31 31 31 31
 0060 31 31 31 31 31 31 31 31 31
 0070 31 31 31 31 31 31 31 31 31
 0080 31 31 31 31 31 31 31 31 31
 0090 31 31 31 31 31 31 31 31 31
 00a0 31 31 31 31 31 31 31 31 31
 00b0 31 31 31 31 31 31 31 31 31
 00c0 31 31 31 31 31 31 31 31 31
 00d0 31 31 31 31 31 31 31 31 31
 00e0 31 31 31 31 31 31 31 31 31
 00f0 31 31 31 31 31 31 31 31 31

再次查詢

HoneyBOT.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

dssetup

No.	Time	Source	Destination	Protocol	Length	Info
33	1.805992	98.114.205.102	192.150.11.111	DSSETUP	454	DsRoleUpgradeDownlevelServer request[Long frame (3208 bytes)]
38	2.134590	192.150.11.111	98.114.205.102	DSSETUP	162	DsRoleUpgradeDownlevelServer response[Long frame (128 bytes)]

Version: 5
 Version (minor): 0
 Packet type: Response (2)
 Packet Flags: 0x03
 Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
 Frag Length: 48
 Auth Length: 0
 Call ID: 1
 Alloc hint: 24
 Context ID: 0
 Cancel count: 0
 [Opnum: 9]
 [Request in frame: 33]
 [Time from request: 0.328598000 seconds]
 Complete stub data (24 bytes)
 Active Directory Setup, DsRoleUpgradeDownlevelServer
 Operation: DsRoleUpgradeDownlevelServer (9)
 [Request in frame: 33]
 Windows Error: WERR_OK (0x00000000)
 Long frame
 [Expert Info (Warning/Protocol): Long frame]
 [Long frame]
 [Severity level: Warning]
 [Group: Protocol]

0000 00 08 e2 3b 56 01 00 00 00
 0010 00 94 05 ac 40 00 00 00 00
 0020 cd 66 01 bd 07 24 00 00 00
 0030 44 70 7e a1 00 00 00 00 00
 0040 00 00 00 98 07 c8 00 00 00
 0050 00 00 00 08 dc 04 00 00 00
 0060 00 00 00 38 00 00 00 00 00
 0070 00 00 05 00 02 03 00 00 00
 0080 00 00 18 00 00 00 00 00 00
 0090 00 00 00 00 00 00 00 00 00
 00a0 00 00

Windows Error (dssetup.werror) 4 byte(s)

Packets: 348, Displayed: 2 (0.6%)

google 搜尋

Active Directory Setup, DsRoleUpgradeDownlevelServer CVE

全部 圖像 影片 新聞 地圖 協助 Duck.ai

始終受到保護 臺灣 安全搜尋：適中 隨時

Search Assist 生成答案

NVD
https://nvd.nist.gov › vuln › detail › CVE-2003-0533

Nvd - Cve-2003-0533

Information Technology Laboratory National Vulnerability Database Vulnerabilities

Broadcom
https://www.broadcom.com › support › security-center › attacksignatures › detail?asid=20615

OS Attack: MS LSASS DS Request CVE-2003-0533

Attack Signature Detail Page Additional Information Microsoft Windows LSASS (Local Security Authority Subsystem Service) is prone to a remotely exploitable stack-based buffer overflow vulnerability. This

CVE-2003-0533

Q7

Which protocol was used to carry over the exploit?

HoneyBOT.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

dssetup

No.	Time	Source	Destination	Protocol	Length	Info
33	1.805992	98.114.205.102	192.150.11.111	DSSETUP	454	DsRoleUpgradeDownlevelServer request[Long frame (3208 b
38	2.134590	192.150.11.111	98.114.205.102	DSSETUP	162	DsRoleUpgradeDownlevelServer response[Long frame (20 by

Frame 33: 454 bytes on wire (3632 bits), 454 bytes captured (3632 bits)
Ethernet II, Src: Cisco_3b:56:01 (00:08:e2:3b:56:01), Dst: SuperMicroCo_62:4e:4a (00:30:48:62:4e:4a)
Internet Protocol Version 4, Src: 98.114.205.102, Dst: 192.150.11.111
Transmission Control Protocol, Src Port: 1828, Dst Port: 445, Seq: 3810, Ack: 795, Len: 400
[3 Reassembled TCP Segments (3320 bytes): #29(1460), #31(1460), #33(400)]
NetBIOS Session Service
SMB (Server Message Block Protocol)
SMB Pipe Protocol
Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Request, Fragment: Single, FragL
Active Directory Setup, DsRoleUpgradeDownlevelServer
Operation: DsRoleUpgradeDownlevelServer (9)
[Response in frame: 38]
Long frame
[Expert Info (Warning/Protocol): Long frame]
[Long frame]
[Severity level: Warning]
[Group: Protocol]

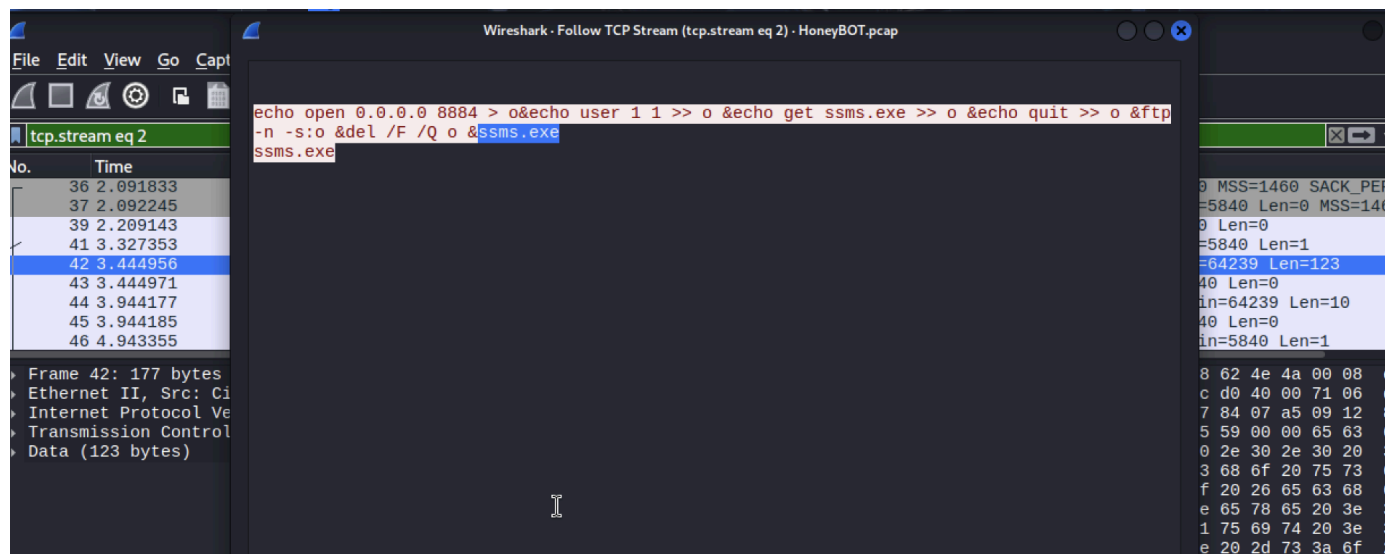
0070 ec 03 00 00 00 00 00 00
0080 90 90 90 90 90 90 90 90
0090 90 90 90 90 90 90 90 90
00a0 90 90 90 90 90 90 90 90
00b0 90 90 90 90 90 90 90 90
00c0 90 90 90 90 90 90 90 90
00d0 90 90 90 90 90 90 90 90
00e0 90 90 90 90 90 90 90 90
00f0 90 90 90 90 90 90 90 90
0100 90 90 90 90 90 90 90 90
0110 90 90 90 90 90 90 90 90
0120 33 c9 66 b9 7d 01 80 34
0130 ff ff ff 70 95 98 99 99
0140 d9 95 12 e9 85 34 12 d9
0150 87 e1 9a 6a 12 e7 b9 9a
0160 c8 12 a6 9a 62 12 6b f3
0170 1a 5e 9d dc 7b 70 c0 c6
0180 48 78 9a 58 aa 50 ff 12
0190 9b 9a 58 12 99 9a 5a 12
01a0 f3 9a c0 71 1e 99 99 99
01b0 c3 12 41 f3 9c c0 71 ed
01c0 98 f3 9b 66 ce 75 12 41
01d0 10 de 9d f3 89 ce ca 66

smb

Q8

Which protocol did the attacker use to download additional malicious files to the target system?

檢查流表Q8，在下一頁



ftp

Q9

What is the name of the downloaded malware?

同上

ssms.exe

Q10

The attacker's server was listening on a specific port. Provide the port number.

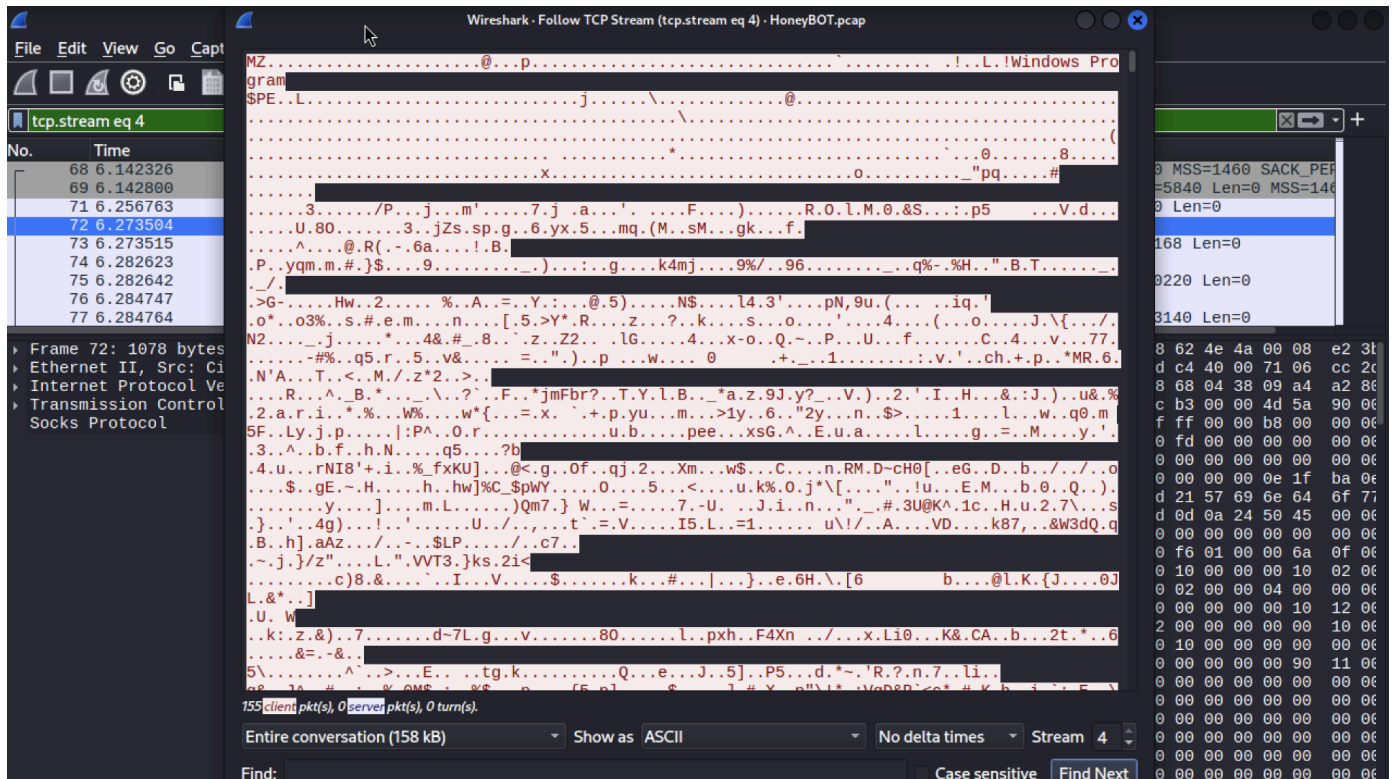
同上

8884

Q11

When was the involved malware first submitted to VirusTotal for analysis? Format: YYYY-MM-DD

不斷往下看，有做什麼執行檔



根據GPT回覆：

ChatGPT ▾

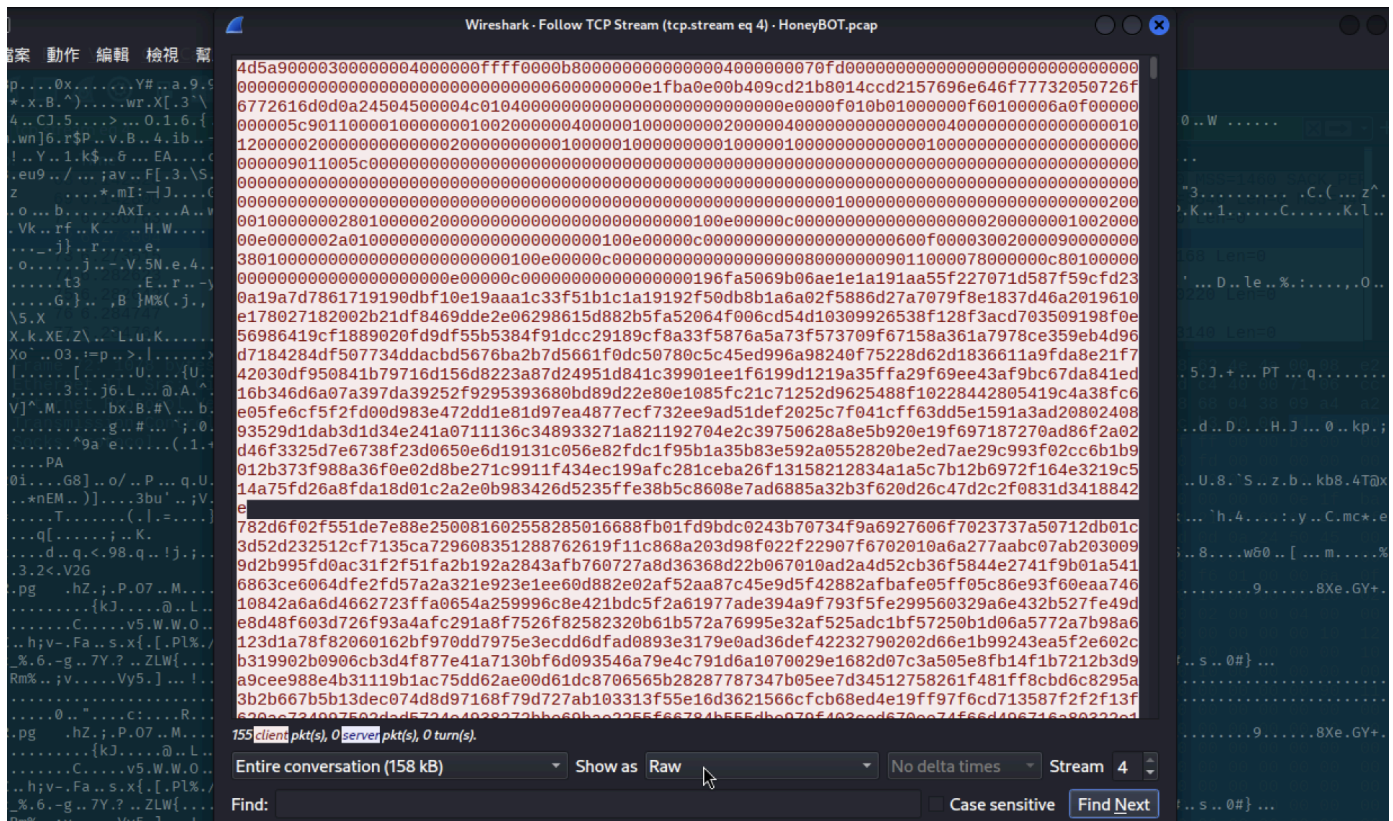
是的，這是一個 Windows 可執行檔（PE 檔案）的內容。

我來解釋原因：

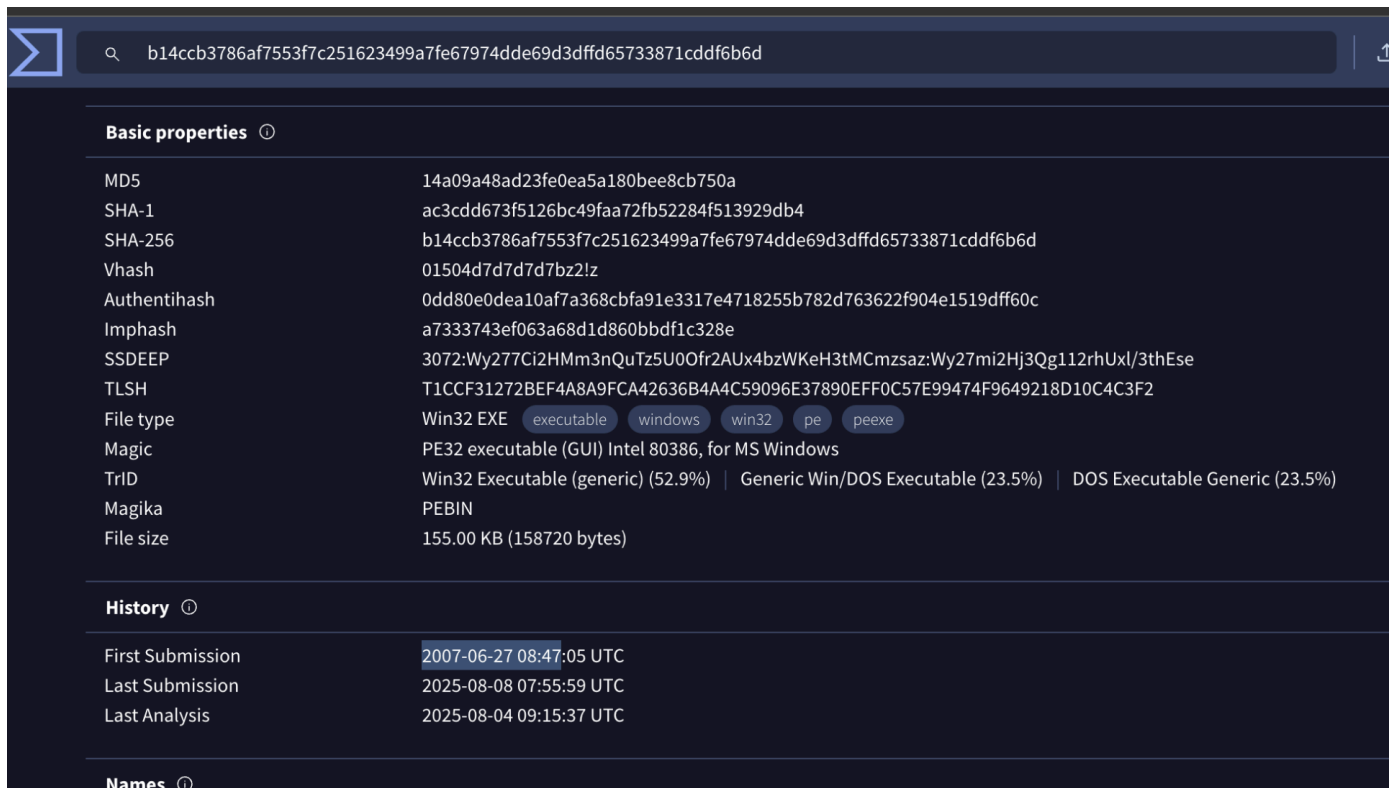
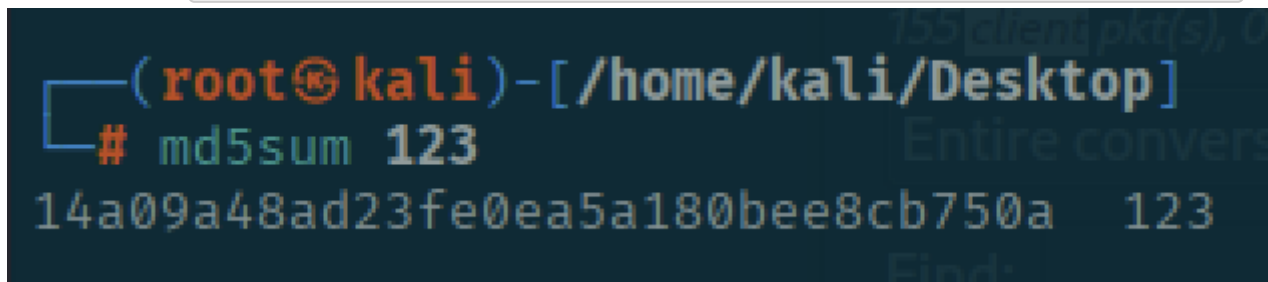
- 開頭的 `MZ` 是 DOS MZ Header，幾乎所有 Windows 執行檔（.exe、.dll 等）都以 `MZ` 開頭。
- 後面不遠處可以看到 `!This program cannot be run in DOS mode.`（雖然部分被截斷），這是標準 PE 檔的訊息。
- `$PE` 標誌出現在檔案中間，是 Portable Executable 格式的標誌。

從畫面上看，你是用 Wireshark 的 Follow TCP Stream 查看一段網路封包的原始資料，這段資料應該是透過網路傳輸的 惡意程式（可能是木馬或惡意 EXE）。

使用raw顯示並進行存檔



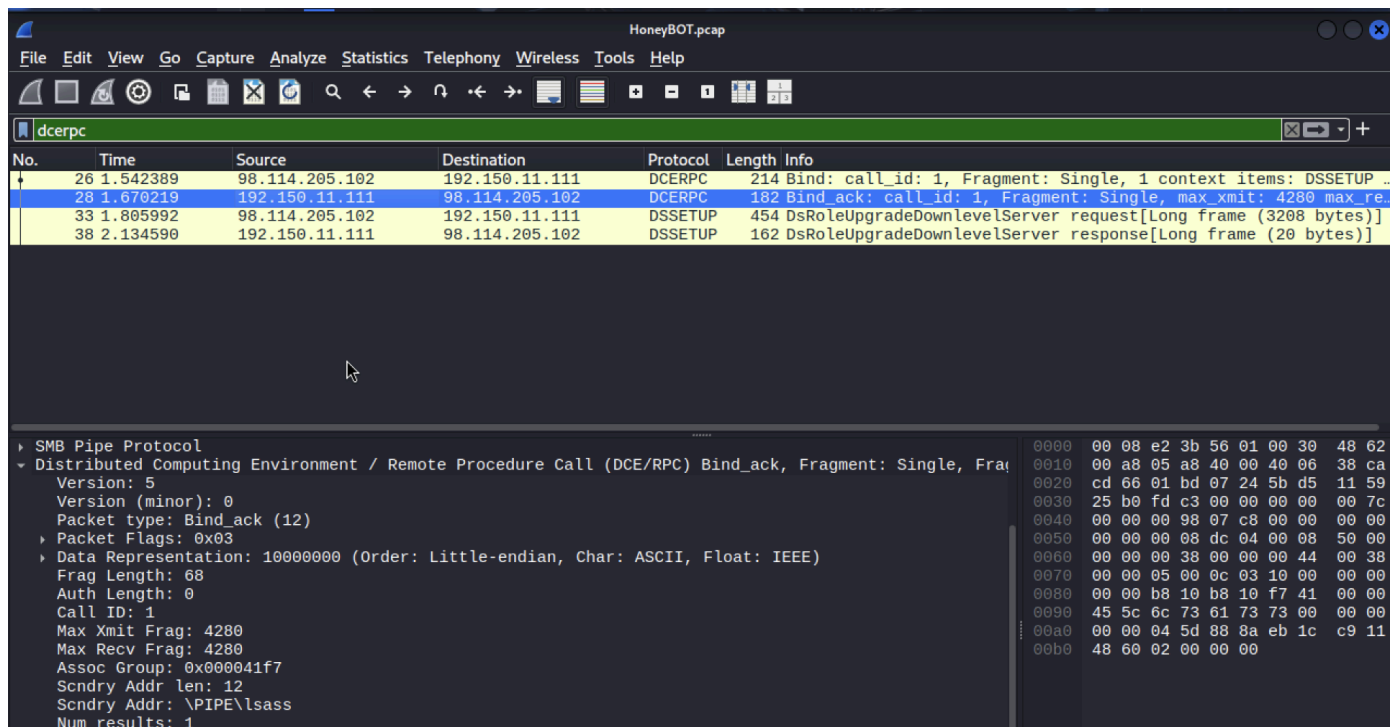
進行md5雜湊 b14ccb3786af7553f7c251623499a7fe67974dde69d3dff65733871cddf6b6d



2007-06-27 08:47

Q12

What is the key used to encode the shellcode?



The image shows a Wireshark packet capture of a DCERPC Bind_ack packet. The packet list shows four packets: a DCERPC Bind request (No. 26), a DCERPC Bind_ack (No. 28), a DSSETUP request (No. 33), and a DSSETUP response (No. 38). The selected packet (No. 28) is a DCERPC Bind_ack from 192.150.11.111 to 98.114.205.102. The packet details pane shows the following structure:

- SMB Pipe Protocol
- Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Bind_ack, Fragment: Single, Fragment Length: 162
- Version: 5
- Version (minor): 0
- Packet type: Bind_ack (12)
- Packet Flags: 0x03
- Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
- Frag Length: 68
- Auth Length: 0
- Call ID: 1
- Max Xmit Frag: 4280
- Max Recv Frag: 4280
- Assoc Group: 0x000041f7
- Scndry Addr len: 12
- Scndry Addr: \PIPE\sass
- Num results: 1

The packet bytes pane shows the raw data of the packet, starting with 00 00 e2 3b 56 01 00 30 48 62.

Q13

What is the port number the shellcode binds to?

Q14

The shellcode used a specific technique to determine its location in memory. What is the OS file being queried during this process?